LOTTE AX CHALLENGE 2026 · 롯데이노베이트 [인프라]

SW 공급망 스캐닝 AI 에이전트

찾기 → 거르기 → 고치기 → 배우기

SBOM과 취약점 스캔 결과를 팀-서비스-부품 그래프에 연결합니다. LLM은 공개 권고문을 조건으로 바꾸고, 코드가 그 조건이 서비스에 있는지 확인해 판정합니다. 업그레이드 조치안과 티켓을 만들고, 사람의 승인·기각으로 다음 판정을 고칩니다.

27 / 30 취약 패키지

서비스별 합계 중 직접 선언하지 않은 부품 (전이 24 + 미참조 3). 직접 선언은 3개

174 → 129 건

스캐너 경고 → 에이전트가 근거와 함께 not_affected로 거른 뒤 (사람 피드백 제외)

99 공유 부품

2개 이상 서비스가 함께 쓰는 패키지 · 한 번의 판단·조치를 여러 서비스에 적용

22.7 초/건

에이전트 건당 판정 시간 · 174건 평균 · LLM 캐시 없이 재실행한 실측

1. 문제: 보이지 않는 부품, 걸러지지 않는 경고

서비스	패키지	직접	전이·미참조	취약 패키지	그중 미선언	경고
podcast4life	235	12	223	21	18	143
wani-briefing-routine	12	5	7	0	0	0
lms-watch	8	2	6	0	0	0
class-toowani	350	2	348	7	7	11
toowani-auth	93	3	90	2	2	20
서비스별 합 고유 628	**698**	**24**	**674**	**30**	**27**	**174**

- 서비스별 취약 패키지 30개 중 27개는 서비스가 직접 선언하지 않은 부품입니다. 선언 파일만 보면 놓칩니다.
  미참조 = 설치돼 있으나 선언 의존성 트리에서 경로가 없는 부품.
- CVSS 상위 10건과 종합 위험(EPSS·노출·업무 중요도) 상위 10건은 5건만 겹쳤습니다. 종합 상위의 평균 EPSS가 2.4배 높습니다.
- 정답셋 56건(AI 초안, 테스트셋 본인 검수 진행 중) 중 affected는 2건뿐입니다. 이를 찾으려면 56건 모두를 사람이 권고문과 코드로 확인해야 합니다.

그래서 순위는 코드로 다시 매김

risk = 100 × 가능성 × 영향. 가능성은 KEV 등재면 1, 아니면 EPSS(없으면 실측 중앙값과 "정보 부족" 표시). 영향은 CVSS/10 × 노출(인터넷 1, 내부 0.5) × 업무 중요도(0.4 / 0.7 / 1) × 개발 전용 0.5입니다(가중치는 가정).

범위: 본인 레포 5개를 가상의 계열사 서비스로 둔 파일럿. 가중치는 가정(`config/scoring.yaml`). 정답셋 라벨: AI 초안 2회(56건) + 테스트셋 본인 검수 진행 중, 튜닝셋 36건은 AI 초안만. 재현: `python -m sca run`. 실행 2026-11-01T03:00:50Z · syft 1.55.0 · grype 0.121.0 · KEV 2026.10.30 · LLM gpt-oss:20b@local

2. 구조: 계산은 코드, 해석은 LLM, 결정은 사람

scan
CODE Syft SBOM (설치 상태) · Grype

ingest
CODE 공통 스키마 · 직접/전이/미참조 구분

enrich
CODE OSV · EPSS · KEV (공개 ID만)

graph·score
CODE 팀-서비스-패키지-취약점, 위험 점수

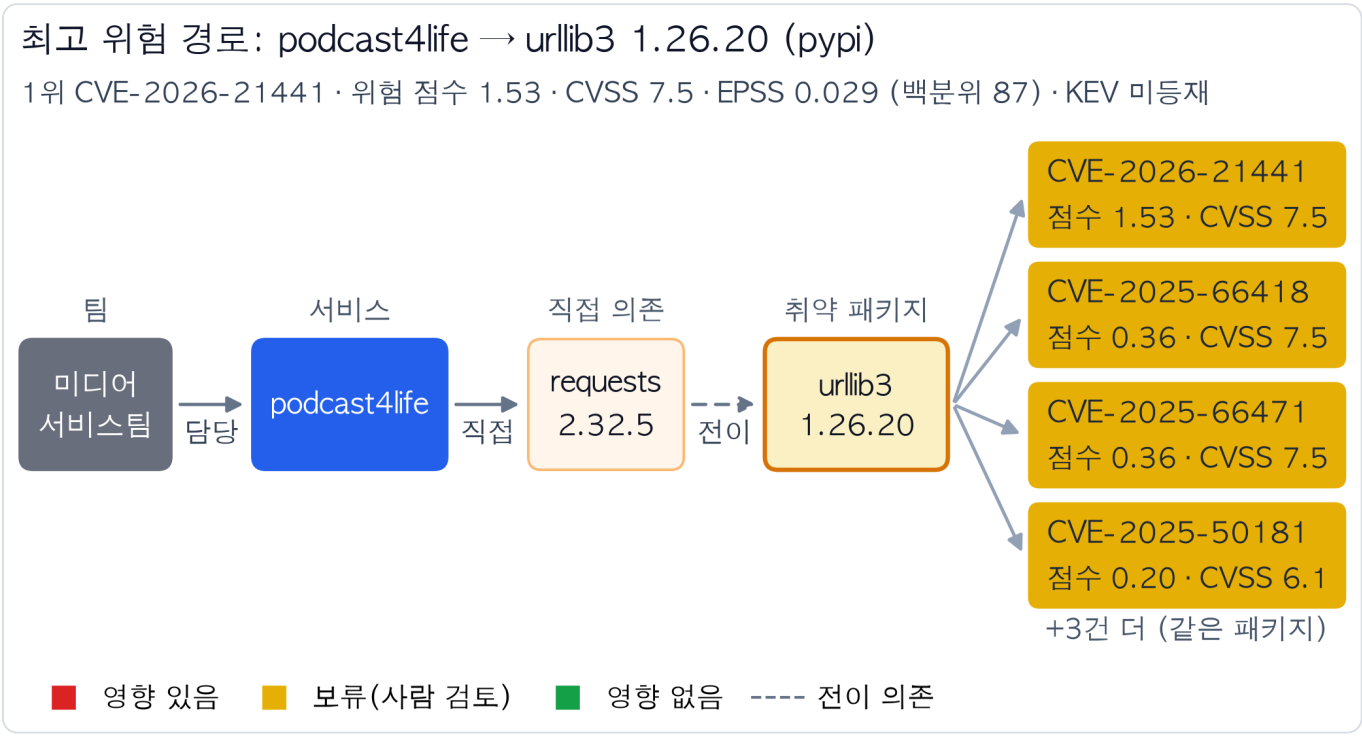
judge
LLM 권고문 → 조건 JSON
CODE 버전 범위·코드 검색 ·판정 규칙

plan
CODE 가중 집합 덮개 Top-3 · 호환성 검사

report
LLM 티켓 서술 (공개 정보만)
CODE CSV·리포트·VEX

feedback·eval
HUMAN 승인·기각 → 다음 판정, 재스캔, 정답셋

최고 위험 경로 (이번 실행 1위)



1위: `pypi:urllib3@1.26.20` · CVE-2026-21441 · 점수 1.534(100점 만점. KEV 등재 0건이라 가능성에 EPSS 값(1위 0.029)이 그대로 들어가 절대값이 작고, 순위 비교용입니다), 전이 의존 (podcast4life가 선언한 `pypi:requests@2.32.5` 경유). 경로·담당팀·점수 근거가 순위 CSV와 티켓에 같이 실립니다.

내부 정보 보호와 교체 가능성

- LLM 입력은 공개 권고문뿐입니다. 노출·중요도·담당팀과 소스 코드는 코드 안에서만 결합합니다.
- OpenAI SDK + base_url 구조입니다. 로컬 모델과 OpenAI는 환경변수만 바꿔 씁니다. 사내 모델도 OpenAI 호환 API라면 같은 방식으로 바꿀 수 있습니다(아이멤버 연동은 미검증).
- 입력 형식이 바뀌면 ingest 파서만 바꿉니다. 나머지 단계는 공통 스키마만 봅니다.

운영 시점과 산출물

기본은 주기 스캔 후 담당팀별 티켓 초안입니다. 산출물은 순위 CSV(점수·판정·경로·수정 버전), Markdown 리포트(KPI·모드 비교·검토 대기열), 티켓 초안(근거 file:line, 호환성 위험, 검증 명령), OpenVEX, KPI JSON입니다.

3. 판정: 근거로 걸러내고, 애매하면 사람에게

LLM은 권고문에서 "어떤 API를, 어떤 입력으로, 어떤 플랫폼에서 써야 터지는가"만 뽑습니다. 권고문에 없는 함수명은 버리고, 인용은 원문과 일치하는지 검사합니다. 코드는 **그 패키지를 import하는 파일**에서만 조건 API를 찾습니다. 서비스 코드와, 그 패키지를 쓰는 의존 패키지의 설치 소스까지 봅니다.

not_affected 근거 규칙: 조건 API 미참조 40건, 플랫폼 제외 5건, 사람 결정(데모) 반영 4건. 조건 API가 코드에 있거나 조건 없이 버전만 맞으면 affected, 결정할 근거가 없으면 보류(사람 검토)입니다.

CVSS 높지만 근거와 함께 not_affected로 걸러진 실제 사례

대상	podcast4life · `pypi:rembg@2.0.61` · CVE-2026-115924 · **CVSS 8.6**
권고문 인용	*"The public `/api/remove` endpoint uses attacker-controlled `extras.sam_model` in both SAM filenames and GitHub download URLs."* (GHSA-qr6x-7v33-6qmg)
추출한 조건	입력 조건: *The attacker must supply a value for the `extras.sam_model` field in the request payload.* (LLM 추출, 영문)
코드 확인	import 8곳: `pipeline/ahn_tag_headaware.py:56`, `pipeline/ahn_tag_headaware.py:84`, `pipeline/ahn_tag_headaware.py:91`, `pipeline/ahn_tag_headaware.py:147`, `pipeline/clearance_v7.py:10` 외 3곳. 조건 심볼 `extras.sam_model` 참조 0건
판정	podcast4life 코드에 rembg@2.0.61 import가 8곳 있지만 권고문의 전제인 extras.sam_model 참조는 0건이어서 not_affected로 판정했습니다(CVSS 8.6). 정답셋 라벨(AI 초안, 본인 검수 진행 중)도 not_affected입니다.

운영 모드 (같은 입력)

모드	경고 감소	사람 검토	결정한 건 중 정답 (테스트셋 20건)	놓친 위험 (테스트셋)
적극 모드 (기본)	45/174건 (25.9%)	117/174건 (67.2%)	8/8건	0건
보수 모드	21/174건 (12.1%)	141/174건 (81.0%)	4/4건	0건

- **적극 모드**: 필수 API나 입력 조건 하나만 코드에 없어도 걸러냅니다. 기본값입니다.
- **보수 모드**: 검색이 완전하고 어떤 조건 API도 없을 때만 not_affected를 냅니다. 놓침 비용이 큰 서비스용입니다.

> 개발 중 교차 검증(구현과 분리된 AI 리뷰 에이전트)에서 오판 경로 6가지(import 이름 불일치, 번들 미검색 등)를 고쳤습니다. 수정 전(v3) 테스트셋: 정확도 55%, 결정한 건 중 정답 11/13건, 놓친 affected 1건(G04 `pypi:lightning@2.6.0`). 이 건은 수정 후 보류로 사람에게 갑니다. 수정 후 정확도는 45%로 낮아졌지만, 틀린 결정이 보류로 바뀐 결과입니다(오판 2→0건).

개선 루프: 사람의 판단이 다음 판정이 됨

- **기록**: 승인·기각과 사유를 저장
- **억제**: 같은 패키지·취약점은 다음 실행에서 자동 정리, `--scope all_services`로 전 서비스 적용
- **예시**: 사유를 few-shot으로 사용(사내·로컬 모델만)
- **검증**: 조치 후 재스캔으로 해당 경고가 사라졌는지 확인(실행별 스냅샷)
- **공유**: OpenVEX v0.2.0으로 판정과 근거 내보내기
- **정답셋**: 검수 시트에 판정·소요 시간을 적으면 정답셋과 지표가 다시 계산됨

4. 결과 (파일럿 측정값)

지표	값	근거
정답 일치 (테스트셋)	9/20건 (45%)	결정 8건 중 정답 8건 + 보류 12건(그중 1건은 정답도 uncertain). 수정 전 v3는 55%였지만 affected 1건을 놓침
자동 처리율	53/174건 (30.5%)	에이전트가 affected·not_affected로 결정한 비율
자동 처리율 (데모 결정 반영)	57/174건 (32.8%)	공유 피드백(데모)으로 정리된 건 포함
오판 (테스트셋)	0/8건	결정한 8건 중 정답과 다른 건 · 피드백 반영 후 0/8건
오판 (튜닝셋)	2/10건	튜닝셋 36건 중 결정 10건. 조건 없이 버전만 맞아 affected(`npm:undici`, 2개 서비스). 전체 56건 기준 정답 16/18건
보류율 (사람 검토)	117/174건 (67.2%)	근거와 함께 검토 대기열로
경고 수	174 → 129건	에이전트 단독 not_affected 45건 제외
공유 판정	판정 18회로 경고 36건	여러 서비스가 같은 패키지@버전×취약점을 공유, 판정 결과 일치
그룹 공유 결정(데모)	2건 → 2개 서비스 4건	전 서비스 범위 결정이 다른 서비스 2건까지 해소 · 시연용 기록
Top-3 위험 커버율	71.2%	not_affected 제외 잔여 위험 대비
처리 시간 (에이전트)	22.7초/건	174건 평균, gpt-oss:20b@local. LLM 캐시 없이 재실행 실측, 중앙값 23.5초
재현성 (캐시 없이)	164/174건 일치 (94.3%)	차이는 LLM 조건 추출 차이. 운영은 조건 캐시로 재현

전부 not_affected로 찍는 기준선 정확도 17/20 = 85% (대신 affected를 하나도 못 잡음). 이 에이전트는 확신할 때만 결정하고 나머지는 보류합니다.

조치안: 업그레이드 Top-3 (가중 집합 덮개)

#	조치	위험 감소	호환성 위험	호환성 위험 없는 대안	다서비스 공유
1	`pillow` 11.3.0 → **13.0.0**	45.3%	메이저 변경(11→13). 목표 버전은 Python >=3.11 필요, 서비스는 3.9.6 → 런타임 업그레이드 필요	없음: 11.x 계열 마지막 릴리스가 현재 11.3.0 — 수정 버전은 12.1.1(Python >=3.10)부터(메이저 변경)	아니오. pillow는 podcast4life에만 설치됨
2	`aiohttp` 3.13.5 → **3.14.4**	14.6%	목표 버전은 Python >=3.10 필요, 서비스는 3.9.6 → 런타임 업그레이드 필요	없음: 3.x 계열 새 릴리스(~3.14.5)는 Python >=3.10 필요, 서비스는 3.9.6 — 수정 버전 3.14.0(Python >=3.10)도 런타임 업그레이드 필요	아니오. aiohttp는 podcast4life에만 설치됨
3	`urllib3` 1.26.20 → **2.8.0**	11.3%	메이저 변경(1→2).	없음: 1.x 계열 마지막 릴리스가 현재 1.26.20 — 수정 버전은 2.5.0(Python >=3.9)부터(메이저 변경)	아니오. urllib3는 다른 서비스에도 설치됐지만 lms-watch(2.8.0), wani-briefing-routine(2.8.0)는 스캔 경고 없음

여러 서비스에 한 번에 효과가 있는 조치: `npm:undici` → 7.30.1 하나로 podcast4life, toowani-auth 2개 서비스의 경고 24건이 해소됩니다(전체 잔여 위험의 7.1%, 계획 순위 4위, 메이저 변경 없음).

5. 보류의 원인과 줄이는 방법

보류 117/174건(67.2%)을 원인별로 나눴습니다. 비율은 전체 경고 대비입니다.

원인	건수	전체 대비	판정 규칙
콜그래프 필요(전이·의존 경로)	87건	50.0%	`reachable_via_dependency` 63, `transitive_needs_callgraph` 24
입력 신뢰 판단 필요(사람)	25건	14.4%	`input_trust_needs_human` 25
검사 불가 조건(사람)	5건	2.9%	`condition_not_checkable` 5

18.8% 검토율 추정

콜그래프 연동 시 근거 추정 (현재 67.2%)

17.2% 검토율 추정

최선의 경우 검토율 하한 (해당 범주 전부 결정 가정)

가정: 콜그래프는 위 87건만 결정. 근거 추정은 정답셋 결정 가능 비율 31/32 적용(AI 초안, 테스트셋 본인 검수 진행 중).

6. 롯데 맥락과 본선 계획

그룹 SI에서의 가치

- 계열사마다 다른 스택을 하나의 서비스-부품 그래프로 봅니다. 공유 부품 99개처럼 겹치는 부품은 판단과 조치를 한 번에 냅니다.
- 내부 자산 정보(노출·중요도·담당팀·소스 코드)는 처음부터 LLM에 보내지 않습니다. LLM을 사내 모델(예: 아이멤버, 연동 미검증)로 바꾸면 공개 권고문 처리도 사내에 남습니다.
- 판정 근거를 OpenVEX로 표준화해, 그룹에서 검증한 뒤 고객사·협력사와 공유합니다.
- EU CRA 보고 의무(2026.09 적용, 전면 2027.12)처럼 SBOM과 대응 이력을 요구하는 규제에 재스캔·VEX 기록으로 대응합니다.

본선(1박 2일) 적용 계획

시간	할 일	완료 기준
1일차 오전	현장 데이터에 맞춰 ingest 파서 교체, 노출·중요도·담당팀 설정 파일 입력	공통 스키마 로드 성공
1일차 오후	환경변수로 OpenAI 모델 연결 후 전체 실행, 표본 정답 라벨링	8단계 실행 완료, 표본 라벨
2일차 오전	표본으로 정확도·보류율 측정, 판정 규칙 조정	조정 전후 측정값 기록
2일차 오후	순위·조치안·티켓 시연	담당팀별 티켓과 리포트 생성

로드맵

- 콜그래프 연동: 전이 의존 보류 건 해소
- PR 게이트: 새 위험만 코멘트·차단
- 샌드박스 테스트 후 자동 PR, 펌웨어·HBOM

7. 산출물 예시와 한계

티켓 초안 예시 (out/tickets/T01-upgrade-pypi-pillow.md 머리말)

[T01] 업그레이드 pypi:pillow 11.3.0 → 13.0.0

- 조치: **업그레이드 pypi:pillow 11.3.0 → 13.0.0**
- 대상 서비스: podcast4life
- 담당팀: 미디어서비스팀
- 위험 감소량: 11.545 (전체 잔여 위험 25.481 중 45.3%, 앞선 티켓과 겹치는 행 제외)
- 호환성 위험: 메이저 버전 변경(11.3.0 → 13.0.0) — 변경 내역·테스트 확인 필요 · Python 런타임 업그레이드 필요(Python 3.9.6 → >=3.11)
- 비고: podcast4life: 목표 버전은 Python >=3.11 필요, 서비스는 3.9.6 → 런타임 업그레이드 필요

이어서 요약·영향·작업 단계(LLM 서술), 해소 취약점 표, 근거(권고문 인용·file:line), 검증 명령, 승인·기각 명령이 붙습니다.

OpenVEX 예시 (out/vex.json, 3쪽 사례)

```
"vulnerability": {"name": "CVE-2026-115924"},
"products": [{"@id": "pkg:pypi/rembg@2.0.61"}],
"status": "not_affected",
"justification": "vulnerable_code_not_in_execute_path",
"impact_statement": "The vulnerable API named in the advisory is not referenced by the produc
t's code."
```

전체 156건: under_investigation 106, not_affected 43, affected 7.

개발·검증 방식

구현은 Claude Code로 했고, 구현과 분리된 검증 에이전트가 네 차례 원시 데이터에서 숫자를 다시 계산하고 코드·제출물을 감사했습니다(docs/verification.md). 검증 에이전트도 AI이므로 독립된 제3자 검증은 아닙니다.

회차	대상	찾고 고친 것
1차	scan·ingest·graph·score	174행 점수·순위 독립 재계산 일치, 분류·중복 결함 4건 수정
2차	judge·plan·feedback·report·eval	모듈별 리뷰 에이전트가 버그 13건 수정, 주요 4건 회귀 테스트
3차	KPI·판정 안전성·조치·유출·문구	not_affected 오판 경로 6가지 수정(규칙 v4), 런타임 호환성 검사 추가
4차	제출물 전체(심사·사실·공개·코드)	비평 71건(high 13) 반영, 재검증 지적 6건 수정, 캐시 없이 재실행

재현성: LLM 캐시를 지우고 전체를 다시 돌리면 판정 164/174건이 같았습니다.

한계

- 파일럿은 본인 레포 5개입니다. KEV 등재 경고가 0건이라 KEV 가중의 효과는 이번 데이터에서 드러나지 않았습니다.
- 정답셋 56건 중 affected가 2건으로 클래스 균형이 맞지 않습니다. 라벨은 AI 초안 2회(56건) + 테스트셋 본인 검수 진행 중, 튜닝셋 36건은 AI 초안만입니다.
- 보류율이 67.2%로 높습니다. 그중 87건이 콜그래프 필요(전이·의존 경로) 범주(의존 패키지 경유 63, 전이 24)라 콜그래프 연동이 다음 과제입니다.
- 테스트셋에서 놓친 위험은 0건이지만 표본이 작아 놓칠 가능성을 배제하지 못합니다. 그래서 보수 모드를 실행 옵션으로 둡니다.